RED TEAM 27

Capstone Security Assessment

Test: Session Hijacking and Cookie Management

Brentwood Bank — Online Account Opening Portal

https://eopen.myvirtualbranch.com/1176/Application

Test conducted by

Pragya Mittal

Client Liason & Security Architect

MSISPM Capstone — Carnegie Mellon University

March 30–April 5, 2026

CONFIDENTIAL

1. Executive Summary

A grey-box penetration test was conducted against the Brentwood Bank online banking portal to assess exposure to session hijacking attacks. The assessment covered session token quality, cookie security attributes, session fixation, session invalidation, CSRF protections, and sensitive data exposure.

The application demonstrated several strong security controls: the primary session identifier (ASP.NET_SessionId) is correctly protected with HttpOnly, Secure, and SameSite=Lax flags; session fixation was not found to be exploitable; and server-side session invalidation on logout was confirmed. However, a number of medium-severity findings were identified, primarily relating to infrastructure-level cookies lacking security attributes, a username disclosed in a cookie, and inconsistent CSRF token implementation.

No direct session hijacking via cookie theft was successfully demonstrated due to the correct protection of the primary session cookie. The risk is mitigated but not eliminated, as supporting cookies lack protection and could aid an attacker in fingerprinting or session-adjacent attacks.

1.1 Risk Summary

Severity	Count	Status
Critical	0	None confirmed
High	0	None confirmed
Medium	4	Confirmed
Low	2	Confirmed
Informational	2	Noted
Pass (Controls Working)	4	Verified

2. Scope & Methodology

2.1 Targets

Domain	Description
www.brentwoodbank.com	Public-facing bank website
secure.myvirtualbranch.com/brentwoodbank/	Online banking portal (primary target)

2.2 Methodology

Testing followed the OWASP Testing Guide (WSTG) session management test cases:

- WSTG-SESS-01: Testing for Session Management Schema
- WSTG-SESS-02: Testing for Cookies Attributes
- WSTG-SESS-03: Testing for Session Fixation
- WSTG-SESS-04: Testing for Exposed Session Variables
- WSTG-SESS-06: Testing for CSRF
- WSTG-SESS-07: Testing for Session Timeout
- WSTG-SESS-09: Testing for Session Hijacking

OWASP ZAP was configured as an intercepting proxy. All traffic between the test browser (Firefox on Ubuntu Linux) and the target was captured. Tracker and analytics domains were excluded from scope. An authenticated test account was used for all post-login testing.

3. Findings

Finding 1 – Infrastructure Cookies Missing Security Attributes [MEDIUM]

Field	Detail
Severity	Medium
Confidence	High – Confirmed
URL	secure.myvirtualbranch.com (Systemic)
CWE	CWE-1004 (Missing HttpOnly), CWE-614 (Missing Secure Flag)
OWASP	A05:2021 – Security Misconfiguration
Affected Cookies	TS0194d6a5, TSPD_101, TS5a522bcf027, TS00000000076, and others

Description

Multiple F5 BIG-IP load balancer and bot-protection cookies are set without the HttpOnly, Secure, and SameSite security attributes. These cookies were confirmed to be accessible via JavaScript using document.cookie in the browser console.

Evidence

The following was executed in the browser console while authenticated:

```
document.cookie
```

The output returned all TS* cookies in plaintext, confirming absence of HttpOnly protection.

```
> document.cookie
<- 'TS0166d10d=01165cd8efa44367569c654a1bb8050a7544637243d893897002be58ee1a8edaaa37c3e48c704f6aeaaface21f
8d877e07854f25081a3e280ed87e1f31e79effb4f5eb30134b41aed1bf5f99e0de12e390a3d8bf674d7eb7351f38c7a9a6fe4a
4e66f556a654693de92417d984c825117f8013ec48e16a1b94558f4f5835a453ad9ac1aa94b6ae7fa0e78c08aa54d583fda483
9090c64610119f603978c9badf3e6c5ffb0c40d40b85ded2246d49cf3332d21fc59e012f7da7beef73d22d8edd7382122a9e;
TS01f3c50a=01165cd8ef4aa1cad763d4e4d95b15c96fcddbfb9559490bfc708d94f852a5257d3b3747f02e5fbdc865edf167b
23eaab1e628ab5290b27cd8c5ea37025c59c282fd53bff2; TS26244048027=086f121d5cab2000de222f31322ccf2fee4e55b
20936b52bd9c7a2345616c4c681a1fb29a2719d1808315fe288113000ae259a8cd7f3a7fd01a52d77c10451f4e38552da5779c
dedcf491c79eb84b76554ec83b124809457d97ed411c5ce2bf4; TS00000000076=086f121d5cab2800c80494300bfa3ecb67c
10511feaad8c57b9e6c001ff42fd8c6eaa30e81193136d3bb408b63efac920884c91bc709d0008d146a5ce1d429716de81110e
0190c899c32ceb9f8605bf413f2ac6f52e7e245b7e3d7a96a6de1940d72425b0aba91bc7e951933d7d52b15ac53b4179c66b74
d254a07b3c3ed1b7945938e2b74c17560437f6fc3e45600aa3c1c06ca6a098a24fc3de84a1cdc8166df23ef745ba7853324f94
a0731a670fb8bc28c06d49642c98f68f800662a6be0e030ccaefd0720871e9efce1cf9f6a30a48190e15243e4e40044277f7a1
7f7b0e5391405342876a4fb72674cc9b1c1a5904c0439348f75f554a9e838750b9ebcba0e68637c7778dd; TSPD_101_DID=08
6f121d5cab2800c80494300bfa3ecb67c10511feaad8c57b9e6c001ff42fd8c6eaa30e81193136d3bb408b63efac920884c91b
c70638001388662f4f83711b506ef58225c6c6988a5f1cdf963929fe630c596ad95851a206080dc905c505ea20d913b752f366
8dbc28898614cf6461; TSPD_101=086f121d5cab2800a215e927e097511af4b5fc06985556c50de26822849363e4726d9fdbe
09ef6547a5caa8c99e2d19508c1ec006b0518006b756d8ac8b6946a3870965d02127ae0367788330d9305c0; TS0194d6a5030
=0147dbf637784383fa0086d5eeb1b5f431550f55eb2539f9340a8e6f0e824710a3f7374490445ce323feaa3e175f795b70ed8
b0af5; TS6531e037077=086f121d5cab2800608d47211344418b7f38e5b7693237f70097cfe0577f21274e6f7e4760e9fdc94
62b7411226d58410888a95c9e17200064110f883d10fbb62b70cdc820bbbeeff6611155c7328327828a434d33ff8ffa; TS019
4d6a5=01165cd8efd1f53c41be312fffa35be4b0471132ca5f55990e012dd752110036f71789dbc15ad156d017231e9700278a
2bc77bab58085171232349974e99ece2db5faa101b062f84de3afb68abbbc773f130a4f948e8ace7afd52903a1028753250356
bd971991eaefa0914e3899c89f55c4ac2cf6d6fd451095fed3bd892d06318399fb4cf4738cd85ed3f205243c661135fb2d2051
c0c31172525ec817dbaca54c5dc0a94ef53d587bfaf589cf122ab1e6454f9ffc945437db8d657dc20ad16a7db868d5; TS6531
e037029=086f121d5cab280071d4d646750cad271cc9a79266eccc61446fa07259643df9e35108cf415508ed62d09a4dcf8a83
7d; TS5a522bcf027=086f121d5cab2000948ce3b075050ff9833013dd223a95a5897dc755a52b897768d171ebbe1968f40801
3a8272113000762295056c76df497657373c8aa3a08a49338400694635d0c05d98b7e22245613e71a380c6b38cf3b76c292bb0
40e4a8'
```

Impact

While these cookies do not directly authenticate users to the application, their exposure could aid an attacker in session fingerprinting, traffic analysis, and potentially bypassing bot-protection controls. In combination with an XSS vulnerability, these cookies could be exfiltrated to an attacker-controlled server.

Recommendation

- Add HttpOnly flag to all cookies that do not require JavaScript access
- Add Secure flag to ensure cookies are only transmitted over HTTPS
- Add SameSite=Lax or SameSite=Strict to all cookies to prevent cross-site transmission

---

Finding 2 – Username Disclosed in Cookie Without HttpOnly [MEDIUM]

Field	Detail
Severity	Medium

Field	Detail
Confidence	High – Confirmed
URL	secure.myvirtualbranch.com (authenticated session)
CWE	CWE-1004, CWE-200 (Exposure of Sensitive Information)
OWASP	A02:2021 – Cryptographic Failures / A05:2021 – Security Misconfiguration
Affected Cookie	1176_Username

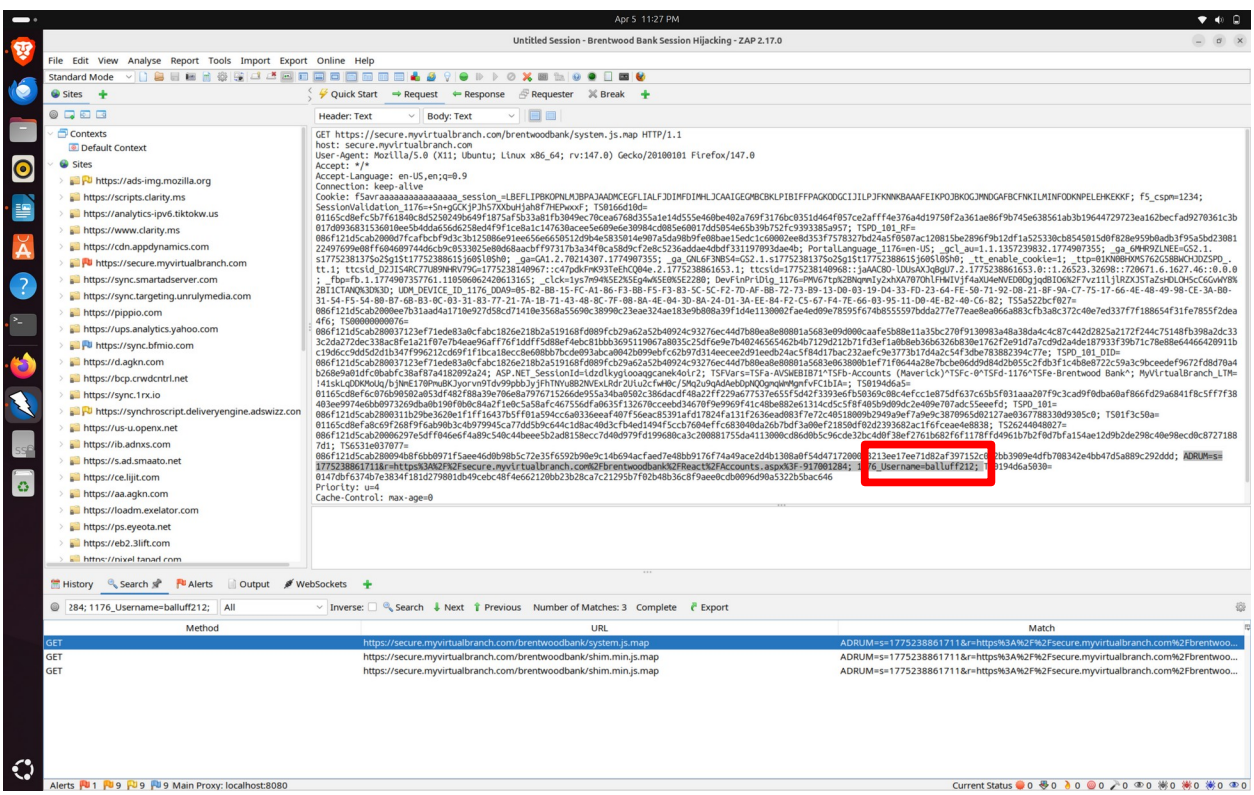
Description

The authenticated session includes a cookie named 1176_Username which contains the plaintext username of the logged-in user. This cookie does not have the HttpOnly flag set, meaning it is accessible via JavaScript.

Evidence

Observed in the Cookie header of authenticated requests:

`1176_Username=balluff212`



Impact

Any XSS vulnerability on the banking portal could be used to exfiltrate the username of the logged-in user without requiring access to the session token itself. This could facilitate targeted phishing or account enumeration.

Recommendation

- Add HttpOnly flag to the 1176_Username cookie
- Evaluate whether the username needs to be stored in a cookie at all, or whether it can be retrieved from the server-side session

---

Finding 3 – Absence of Anti-CSRF Tokens on Some Endpoints [MEDIUM]

Field	Detail
Severity	Medium
Confidence	Medium
URL	secure.myvirtualbranch.com (2 endpoints flagged by ZAP)
CWE	CWE-352 – Cross-Site Request Forgery
OWASP	A01:2021 – Broken Access Control

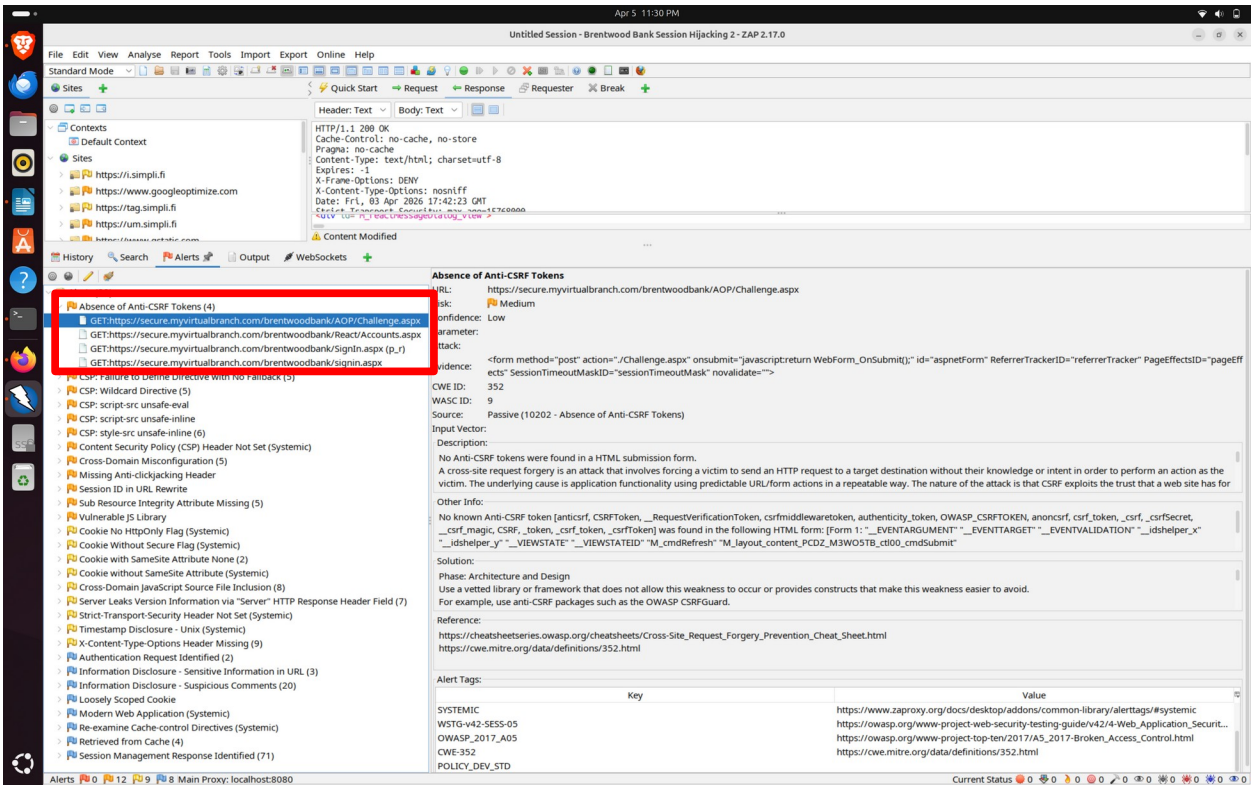
Description

ZAP identified two endpoints that do not implement Anti-CSRF tokens. Notably, CSRF tokens (X-CSRF-Token header) were observed on other authenticated POST requests to MCMRequest.aspx, indicating inconsistent implementation across the application.

Evidence

CSRF token present on some requests:

```
X-CSRF-Token: uR7xWJOFfngQ9xZwH5vRs9qZfwNEkZ8baXZk6ulH1EQ=
```



Impact

Endpoints lacking CSRF tokens combined with cookies missing SameSite attributes could allow an attacker to craft a cross-site request that performs actions on behalf of an authenticated user.

Recommendation

- Ensure all state-changing requests implement and validate CSRF tokens consistently
- Add SameSite=Lax or Strict to all session-related cookies as a defence-in-depth measure

---

Finding 4 – Strict-Transport-Security Header Not Set [MEDIUM]

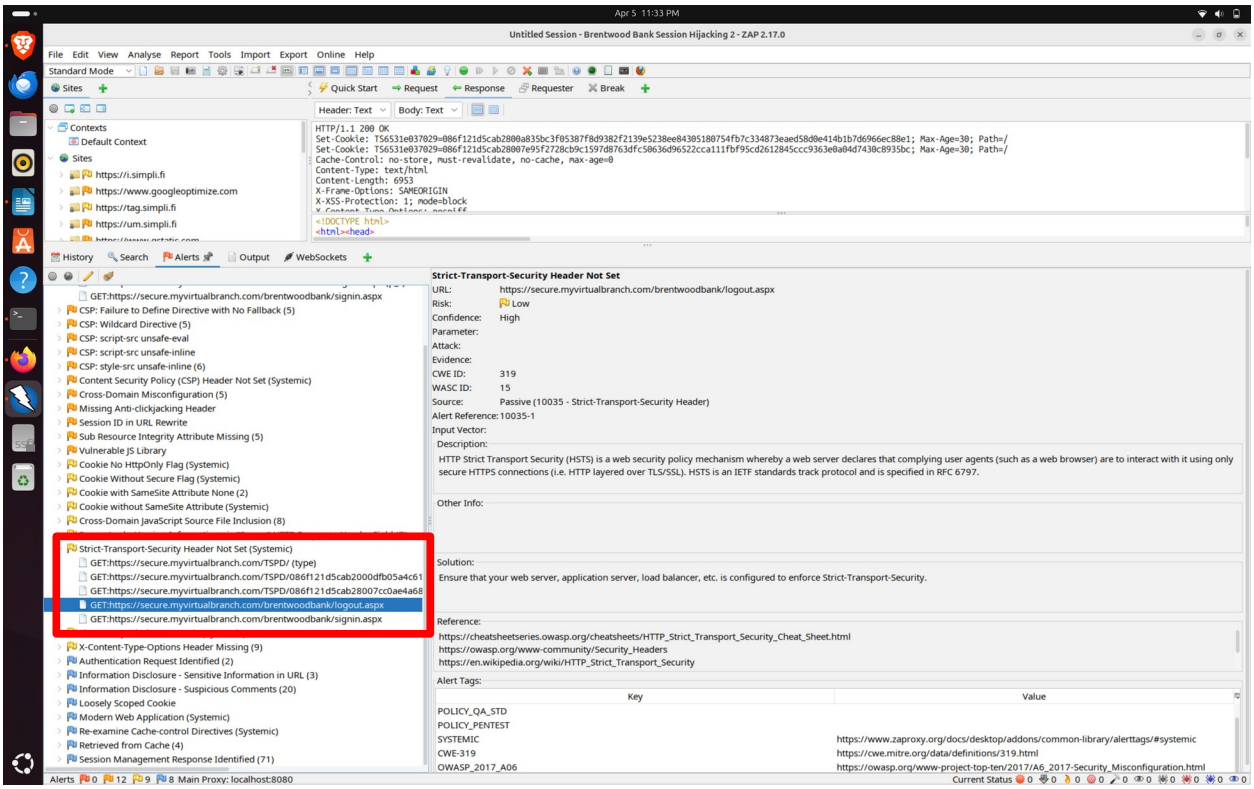
Field	Detail
Severity	Medium
Confidence	High – Confirmed

Field	Detail
URL	www.brentwoodbank.com and secure.myvirtualbranch.com (Systemic)
CWE	CWE-319 – Cleartext Transmission of Sensitive Information
OWASP	A05:2021 – Security Misconfiguration

Description

The Strict-Transport-Security (HSTS) header is not set on the main bank domain. Without HSTS, browsers will not enforce HTTPS-only connections, leaving users potentially vulnerable to SSL stripping attacks on the initial request.

Note: secure.myvirtualbranch.com does set HSTS with max-age=15768000 (~6 months). The finding applies primarily to www.brentwoodbank.com.



Recommendation

- Add Strict-Transport-Security: max-age=31536000; includeSubDomains to all responses from brentwoodbank.com
- Consider adding the domain to the HSTS preload list

Finding 5 – Logout Response Does Not Explicitly Invalidate Session Cookie [LOW]

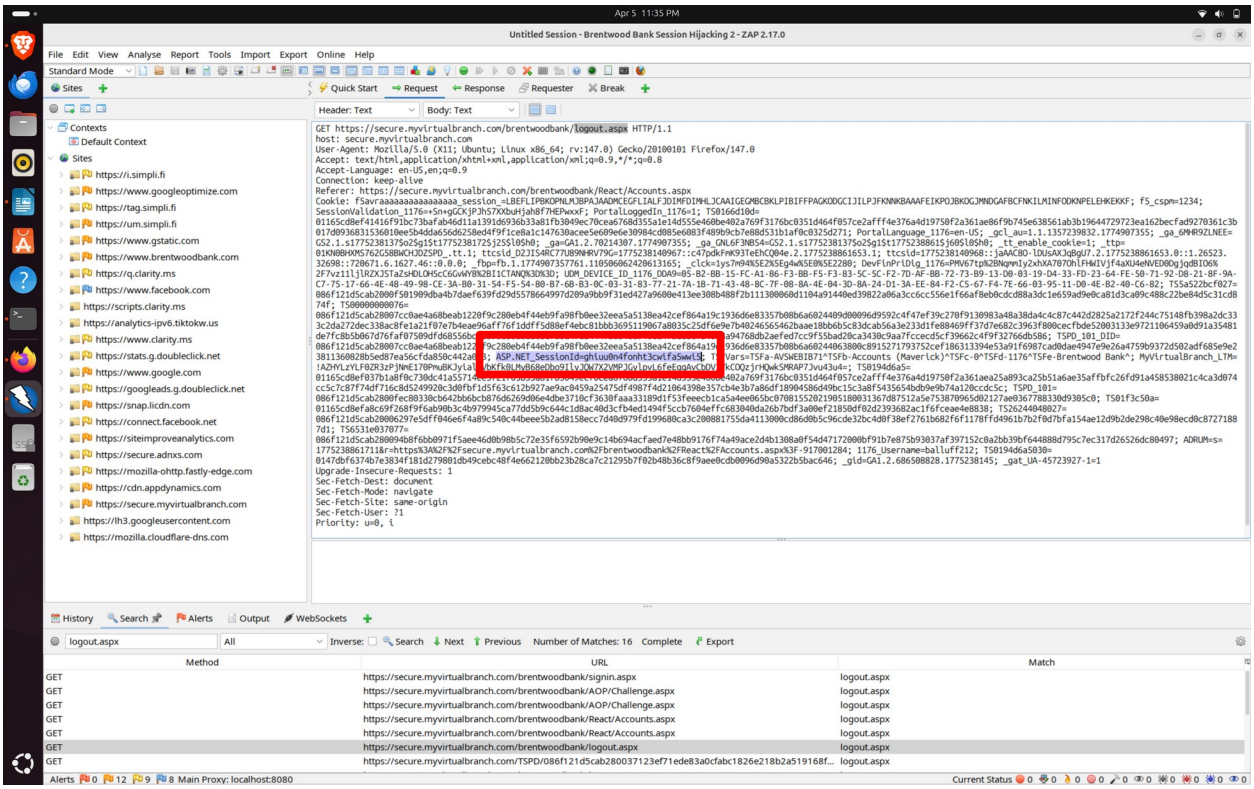
Field	Detail
Severity	Low
Confidence	Medium
URL	secure.myvirtualbranch.com/brentwoodbank/logout.aspx
CWE	CWE-613 – Insufficient Session Expiration
OWASP	A07:2021 – Identification and Authentication Failures

Description

The logout response does not include a Set-Cookie header to explicitly clear or expire the ASP.NET_SessionId cookie. Best practice requires the logout response to actively invalidate the session cookie by setting it with an expired date or empty value.

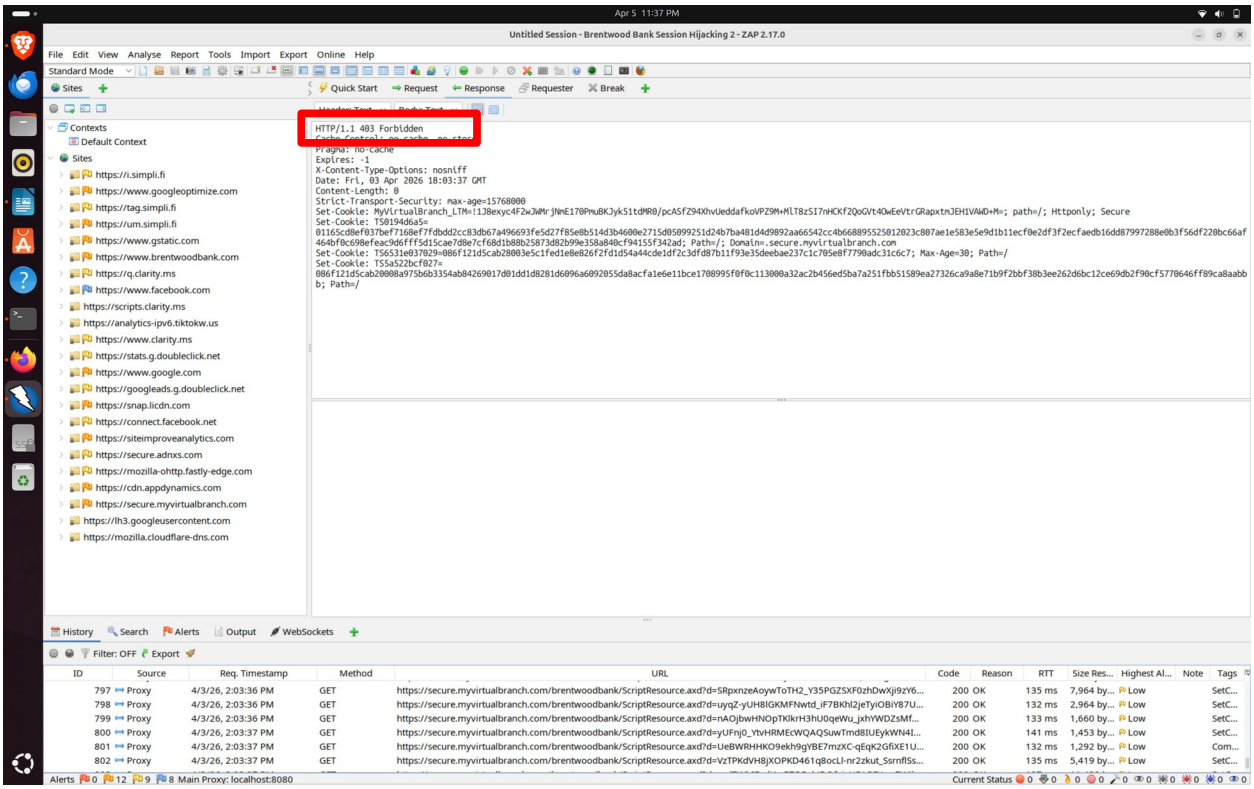
Evidence

Logout response headers observed – no session cookie invalidation present:



Mitigating Factor

Testing confirmed that server-side session invalidation IS functioning correctly – replaying the old ASP.NET_SessionId after logout resulted in a 403 Forbidden response and redirect to the login page. The absence of explicit cookie clearing is therefore a defence-in-depth gap rather than a critical vulnerability.



Recommendation

- Update the logout handler to explicitly expire ASP.NET_SessionId in the response: Set-Cookie: ASP.NET_SessionId=; expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/; secure; HttpOnly

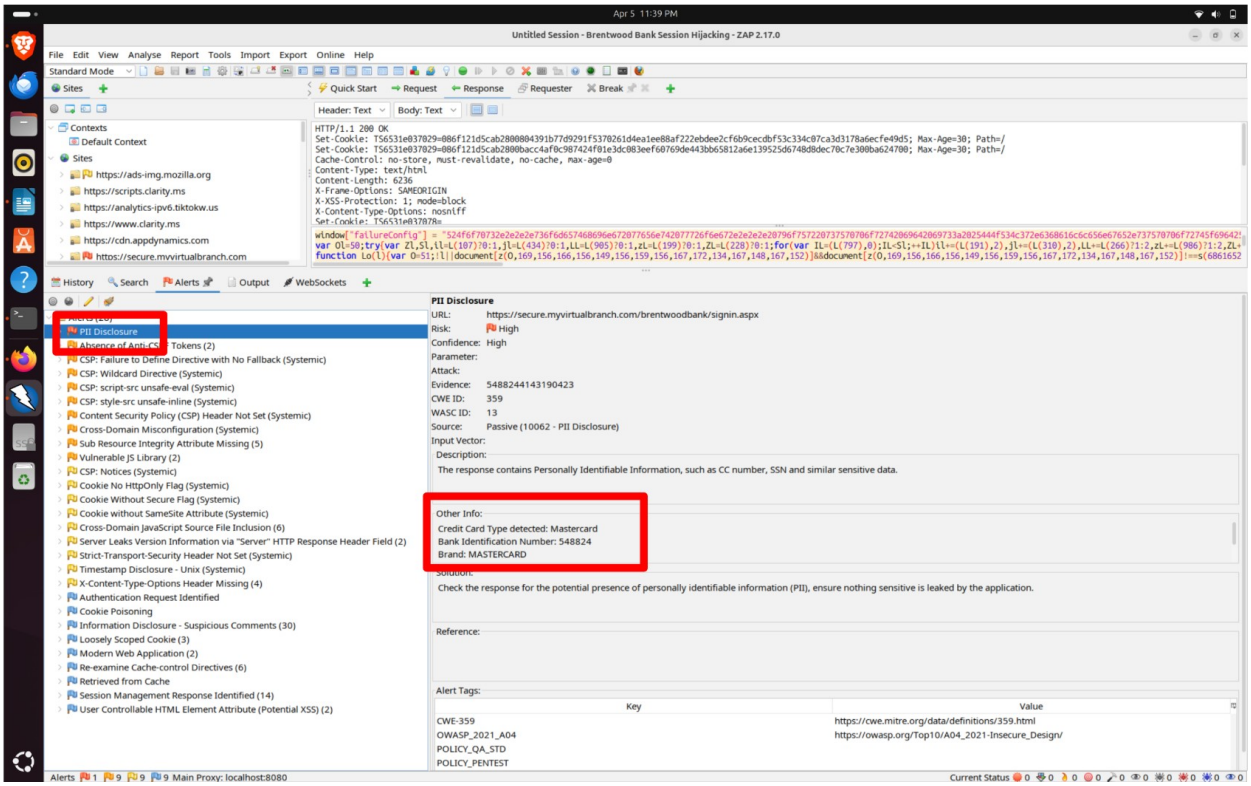
---

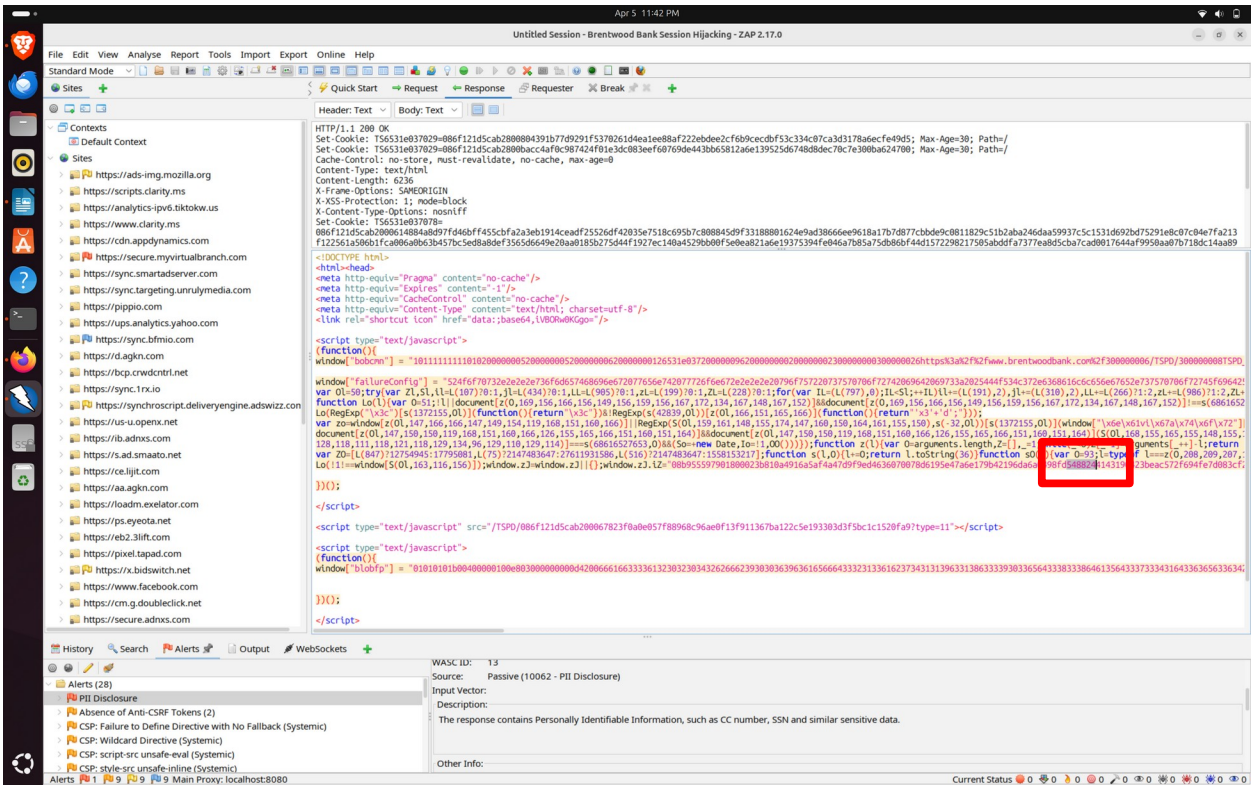
Finding 6 – PII Disclosure Alert – False Positive [INFORMATIONAL]

Field	Detail
Severity	Informational (False Positive)
Confidence	Low – Manual review inconclusive
URL	secure.myvirtualbranch.com/brentwoodbank/signin.aspx
CWE	CWE-359 (flagged by tool, not confirmed)
OWASP	A04:2021 – Insecure Design (flagged by tool)

Description

ZAP flagged a 16-digit sequence (5488244143190423) matching a Mastercard BIN pattern within the signin.aspx response. Manual review of the response body confirmed this number is embedded within the window.zJ.iZ JavaScript variable, which is part of the F5 BIG-IP bot protection fingerprinting script, not an application response containing payment data.





Assessment

This is assessed as a false positive. The pattern match coincidentally occurs within an encoded bot-protection token. No genuine payment card data was found exposed in any application response.

Recommendation

No immediate action required. Development team should review the F5 bot protection configuration to confirm no sensitive data is inadvertently included in client-side fingerprinting tokens.

4. Controls Verified as Working

Control	Test Performed	Result
ASP.NET_SessionId protection	Attempted JavaScript extraction via document.cookie	PASS – Cookie not accessible via JS (HttpOnly confirmed)
Session Fixation	Compared session ID before and after login	PASS – New session ID issued on authentication
Server-Side Session Invalidation	Replayed pre-logout session token after logout	PASS – 403 Forbidden returned, session destroyed
CSRF Token Implementation	Inspected authenticated POST requests	PASS – X-CSRF-Token present on sensitive requests

5. Consolidated Findings Table

#	Finding	Severity	CWE	OWASP	Status
1	Infrastructure cookies missing HttpOnly/Secure/SameSite	Medium	CWE-1004, CWE-614	A05:2021	Confirmed
2	Username exposed in cookie without HttpOnly	Medium	CWE-1004, CWE-200	A02:2021	Confirmed
3	Absent Anti-CSRF tokens on some endpoints	Medium	CWE-352	A01:2021	Confirmed
4	HSTS header missing on main domain	Medium	CWE-319	A05:2021	Confirmed
5	Logout does not explicitly clear session cookie	Low	CWE-613	A07:2021	Confirmed
6	PII Disclosure – ZAP alert	Info	CWE-359	A04:2021	False Positive

6. Recommendations Summary

Priority	Recommendation
1 – Medium	Add HttpOnly, Secure, and SameSite=Lax flags to all TS* infrastructure cookies
2 – Medium	Add HttpOnly flag to 1176_Username cookie or remove username from client-side cookie entirely
3 – Medium	Implement CSRF token validation consistently across all state-changing endpoints
4 – Medium	Add HSTS header to www.brentwoodbank.com (Strict-Transport-Security: max-age=31536000; includeSubDomains)
5 – Low	Update logout handler to explicitly expire ASP.NET_SessionId in the Set-Cookie response header
6 – Info	Review F5 bot protection configuration to confirm no PII is inadvertently included in fingerprinting tokens

Appendix A – Cookie Attribute Inventory

Cookie	HttpOnly	Secure	SameSite	Risk
ASP.NET_SessionId	Yes	Yes	Lax	None – Properly secured
TSFVars	Yes	Yes	Lax	None – Properly secured
MyVirtualBranch_LTM	Yes	Yes	Missing	Low
f5_cspm	Yes	No	Missing	Low
TS0194d6a5	No	No	Missing	Medium – JS accessible
TSPD_101	No	No	Missing	Medium – JS accessible
TS5a522bcf027	No	No	Missing	Medium – JS accessible
TS00000000076	No	No	Missing	Medium – JS accessible
1176_Username	No	No	Missing	Medium – Username exposed
TS6531e037029	No	No	Missing	Medium – JS accessible

Appendix B – References

- OWASP Testing Guide: https://owasp.org/www-project-web-security-testing-guide/
- CWE-1004 – Sensitive Cookie Without HttpOnly Flag: https://cwe.mitre.org/data/definitions/1004.html
- CWE-352 – Cross-Site Request Forgery: https://cwe.mitre.org/data/definitions/352.html
- CWE-613 – Insufficient Session Expiration: https://cwe.mitre.org/data/definitions/613.html
- OWASP A07:2021 – Identification and Authentication Failures: https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/
- OWASP HttpOnly: https://owasp.org/www-community/HttpOnly